

BLISS-SYS-PROD-020

Bliss Bot Chapel

production posture report

Phase 20: fail-closed production gates, encrypted data-protection keys, role-claim mapping, posture visibility, and a local backup/restore drill.

Item	Value
Application	Bliss Bot Chapel — API, operations console, and public site
Runtime	Linux, .NET SDK 8.0.425, ASP.NET Core
Date	29 September 2026
Baseline	BLISS-SYS-NEGREG-001 — 172 of 172 regression tests
Branch / commit	cursor/production-posture-hardening-d942 · 9d3b748
Credentials	Process environment only. None committed; none in captured responses.

Overall result

Outside Development the API now refuses to start until the hosted database, identity provider, secrets, role claims, encrypted key ring, deployment proxy, and backup declaration are configured. The regression suite grew from 172 to 200 tests and passed completely.

This is not a completed production deployment. The production-shaped probe used a non-routable documentation database address (203.0.113.10). No organizational identity provider was contacted. The backup drill ran on local PostgreSQL 16.

Suite	Result
Regression	200 passed , 0 failed, 0 skipped
Production-shaped startup	Started with every gate satisfied; posture reported gates applied
Unsafe production startup	Rejected before serving, exit 134, no secrets in the message
Health separation	Live 200 · Ready 503 with the database unreachable · Posture 200
Anonymous production access	/api/creators 401 · /api/runtime/status 401
Data-protection key	Key XML encrypted; a second process unprotected the payload
Role claims	ID-token and userinfo roles both honored, including JSON arrays
Request logging	Path, status, request id, duration; query string omitted

Suite	Result
Backup drill	Local dump → drop → restore matched the marker
Browser	Status shows Deployment posture; Development reports gates Not applied

1. What closes the NEGREG-001 boundaries

NEGREG-001 boundary	Phase 20 response
Key persisted without an XML encryptor	Keys are encrypted with a PKCS#12 certificate. Production refuses to start without it.
Userinfo-only roles were not applied	The configured role claim is read from userinfo and the ID token and aligned on the session cookie.
Local PostgreSQL acceptance database	Production rejects loopback hosts, requires SSL, and rejects weak or committed passwords.
Local OIDC acceptance provider	Production requires an HTTPS, non-loopback authority and a secret-store client secret.
Single-host load figures	Not changed. Still not a capacity claim; production load testing remains a later gate.

2. Production startup gates

These are checked before the app is built. Any failure throws `Production posture is incomplete` and lists every missing item without echoing values.

- Connection string supplied outside `appsettings*.json`; non-loopback host; username, database name, and a non-placeholder password.
- `SSL Mode` of `Require`, `VerifyCA`, or `VerifyFull`.
- OIDC enabled; HTTPS non-loopback authority; client id; secret-store client secret.
- Distinct roles `bliss.viewer`, `bliss.operator`, `bliss.viewer`, `bliss.admin`, `bliss.advertiser`.
- Persistent key directory plus a readable PKCS#12 certificate and password.
- At least one non-loopback `Runtime:KnownProxies` address.
- Backup provider, schedule, and retention of 1-3650 days.

Rejected startup

Loopback database, `SSL Mode=Disable`, no certificate, no proxy, no backup declaration. The process exited **134**:

```
Production posture is incomplete. The database host must be a hosted address outside
Development. Loopback hosts are rejected. The database connection must set SSL Mode to Require,
VerifyCA, or VerifyFull outside Development. Runtime:DataProtectionCertificatePath is required
outside Development so persisted keys are encrypted at rest.
Runtime:DataProtectionCertificatePassword must be supplied through the secret store.
Runtime:KnownProxies must include at least one non-loopback deployment proxy outside
Development. Runtime:Backup:Provider, Runtime:Backup:Schedule, and a positive
Runtime:Backup:RetentionDays are required outside Development.
```

3. Production-shaped process

Started as `Production` with a hosted-shaped connection string (`SSL Mode=Require` , one-second timeout), HTTPS authority `identity.example.test` , a PKCS#12 certificate, proxy `10.0.0.10` , and a platform-managed daily backup declaration.

Probe	HTTP	Result
GET <code>/health/live</code>	200	Process Healthy
GET <code>/health/ready</code>	503	Database Unhealthy — “Database connection failed.”
GET <code>/health/posture</code>	200	Gates applied; keys encrypted at rest
GET <code>/api/creators</code>	401	Anonymous access rejected
GET <code>/api/runtime/status</code>	401	Anonymous access rejected

Posture document

Field	Value
<code>productionGatesApplied</code>	Yes
<code>keysEncryptedAtRest</code>	Yes
<code>hostedDatabaseConfigured</code>	Yes
<code>databaseTransportEncrypted</code>	Yes
<code>databaseServerCertificateVerified</code>	No — <code>SSL Mode=Require</code> , not <code>VerifyFull</code>
<code>identityProviderHttps</code>	Yes
<code>roleClaimType / roles</code>	<code>roles</code> · <code>bliss.viewer</code> , <code>bliss.operator</code> , <code>bliss.reviewer</code> , <code>bliss.admin</code> , <code>bliss.advertiser</code>
<code>roleClaimsDistinct</code>	Yes
<code>knownProxiesConfigured</code>	Yes
<code>backup</code>	<code>platform-managed</code> · <code>daily</code> · 14 days
<code>secretMaterialExternal</code>	Yes

No response body contained the database password, client secret, or certificate password. The key file contained `EncryptedData` and no plaintext `<value>` .

4. Automated tests added

Area	Proved
Posture evaluator	Development skips hosted gates; a full hosted declaration passes; <code>Require</code> vs <code>VerifyFull</code> reported correctly
Negative configuration	Loopback hosts, SSL disabled, weak passwords, HTTP or loopback identity, placeholder and committed secrets, duplicate roles, secret-like backup provider, loopback-only proxy, missing certificate

Area	Proved
Secret hygiene	Failure messages never echo secrets; committed appsettings keep secrets empty; wrong certificate password not echoed
Role claims	Userinfo array grants admin; userinfo reviewer cannot write; JSON-array claim normalized; cookie alignment; OIDC userinfo event
Production host	Live/ready/posture split; anonymous 401; encrypted key round-trip across processes; 48 concurrent liveness reads all 200
Startup rejection	Production without a certificate fails before serving
Logging	Request log omits query-string tokens
Backup script	Refuses to run without the explicit local opt-in

Command: `dotnet test Bliss.Tests/Bliss.Tests.csproj --verbosity minimal` — **200 passed, 0 failed, 0 skipped.**

5. Local backup/restore drill

PostgreSQL 16.15 on loopback with `BLISS_BACKUP_DRILL=1` and `BLISS_BACKUP_DRILL_TARGET=local`. The script created a scratch database, wrote a marker, dumped it with `pg_dump -Fc`, dropped the database, restored it, and compared the marker.

```
Backup drill restored marker marker-20260929T040401Z-6156.
```

This proves the procedure only. It is not a restore of a hosted Alpha backup.

6. Browser evidence

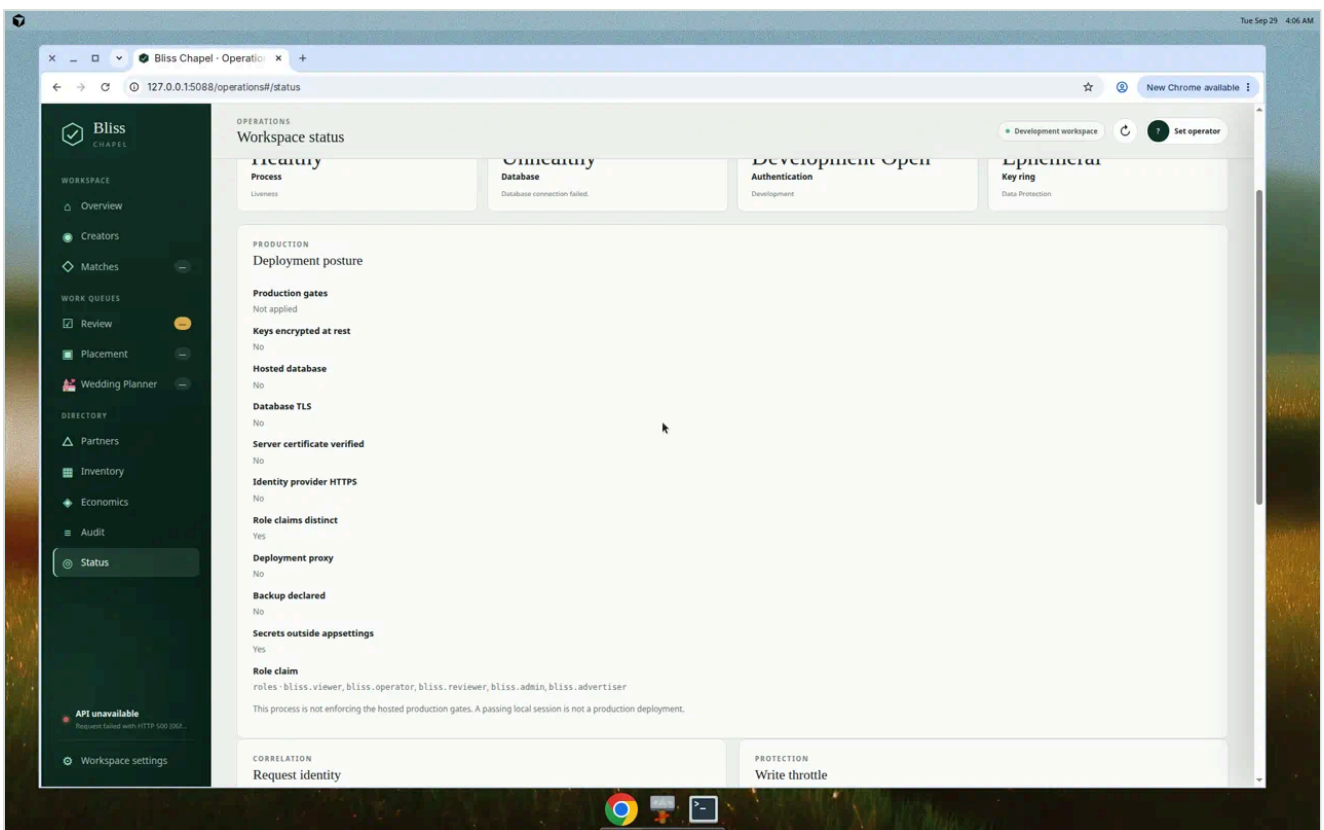


Figure 1. Development Status workspace. Deployment posture reports production gates Not applied, role claim roles with all five roles, and secrets outside appsettings. The database is Unhealthy because this process had no connection string.

The walkthrough also navigated to Overview and back; the posture panel remained. Business reads returned HTTP 500 while the connection string was empty, and Status still rendered from `/api/runtime/status`. Recording: `bliss-phase20-deployment-posture.mp4`.

7. Remaining gates

- Hosted Alpha PostgreSQL has not been migrated or queried.
- No organizational identity provider has issued a token.
- `SSL Mode=Require` does not verify the server certificate; move to `VerifyFull` once the provider CA is available.
- The certificate password must live in the platform secret store. No cloud KMS yet.
- The backup declaration is configuration; a hosted restore has not been performed.
- Production load and performance testing has not been performed.
- Review and merge are pending on pull request #50.